

Reporte Ejecutivo de Gestión de Riesgos

Clínica Privada — Relevamiento inicial de riesgos de seguridad de la información

Preparado para: Directorio

Elaborado por: Gastón Álvarez (Responsable de Seguridad de la Información)

1. Resumen Ejecutivo

Como parte del plan de mejora continua en materia de seguridad de la información, y a raíz de las debilidades identificadas en la reciente auditoría externa, se llevó adelante un relevamiento inicial de riesgos utilizando la herramienta SimpleRisk. Se identificaron y evaluaron 7 riesgos específicos asociados a la operación de la clínica (120 empleados, ~800 pacientes atendidos por día, manejo de historias clínicas digitales, datos de obras sociales y facturación). De ellos, 1 fue clasificado como crítico y 3 como de nivel alto, concentrados principalmente en el manejo de datos sensibles de pacientes y en la exposición de la infraestructura tecnológica a amenazas externas (ransomware, phishing). Se definieron planes de acción concretos para los tres riesgos de mayor prioridad, con responsables, plazos y requisitos de seguridad asociados.

2. Top 5 Riesgos por Nivel

ID	Riesgo	Categoría	Nivel	Puntaje
R02	Ransomware en servidores de facturación	Vuln. Técnica	Crítico	8.0
R01	Acceso no autorizado a historias clínicas	Gestión de Accesos	Alto	6.4
R04	Phishing dirigido al personal administrativo	Datos Sensibles	Alto	6.0
R05	Filtración de datos por dispositivos móviles (BYOD)	Política y Procedimiento	Alto	4.8
R07	Incumplimiento normativo por retención de datos	Datos Sensibles	Medio	3.6

El detalle completo de los 7 riesgos identificados, con su justificación, controles existentes y propietario, se encuentra documentado en el informe técnico anexo.

3. Estado de los Planes de Acción

Riesgo	Plan de acción	Esfuerzo	Fecha objetivo	Estado
R02 (Crítico)	Backups offline, segmentación de red y EDR	Significativo	15/11/2026	Planificado
R01 (Alto)	Control de acceso por roles (RBAC) y auditoría	Considerable	30/10/2026	Planificado
R04 (Alto)	MFA en correo institucional y capacitación	Menor	15/10/2026	Planificado

4. Recomendaciones Prioritarias

- **Habilitar autenticación multifactor (MFA)** en el correo institucional de forma inmediata: es la medida de menor costo y mayor impacto frente al riesgo de phishing.
- **Priorizar la implementación de backups offline e inmutables** para los servidores de facturación, dado el riesgo crítico de ransomware identificado en el sector salud a nivel mundial.
- **Implementar control de acceso basado en roles (RBAC)** y habilitar registros de auditoría sobre el sistema de historias clínicas electrónicas, para dar cumplimiento a la Ley 25.326 de Protección de Datos Personales.
- **Formalizar una política de uso de dispositivos personales (BYOD)** y una política de retención y borrado de datos, actualmente inexistentes.
- **Asignar un presupuesto anual fijo** de seguridad de la información y realizar un nuevo relevamiento de riesgos con periodicidad semestral.

Documento elaborado en el marco del Trabajo Práctico de Administración de Riesgos Seguridad de Sistemas. Los datos de la organización corresponden a un escenario simulado con fines académicos.